

Evaluation Framework: Comparing AI-Generated Security Policies

This evaluation compares two versions of a cybersecurity policy for a small hospital, both generated using AI tools:

- **Policy 1:** *Benchmark policy*, generated by **ChatGPT (OpenAI)**.
- **Policy 2:** *Test policy*, generated by a **system under evaluation** (e.g., custom RAG pipeline or alternative LLM approach).

The goal is to identify which version performs best in terms of relevance, completeness, compliance, and usability in a real-world healthcare environment.

Note on Evaluation Bias: We acknowledge that using ChatGPT as both the benchmark generator and the evaluator may introduce bias in favor of its own outputs. We are currently exploring ways to mitigate this, including the use of independent reviewers, objective scoring rubrics, and external validation tools.

Comparison Table

Criterion	Policy 1 – Benchmark (ChatGPT)	Policy 2 – System Under Evaluation	Winner
Completeness	Covers core areas but omits business continuity and patching	Full scope, including risk analysis, DR, patch management	Generated
Regulatory Compliance	Strong: Explicit GDPR, NIS2, ISO references	Weaker: Implicit references, less formal linkage	Benchmark
Contextualization	Generic, applies to any hospital	Tailored to a small hospital (10 doctors, 100 beds, €10M turnover)	Generated
Governance & Risk Management	Describes structure but lacks detailed risk analysis	Includes risk assessment and mitigation planning	Generated
Clarity and Readability	Clear, concise, well-structured	Equally clear and professional	🥷 Tie
Practical Applicability	Good but some recommendations are abstract	High: grounded in operational constraints and examples	Generated
Currency and Referencing	Strong normative sources (ENISA, GDPR, ISO/IEC 27001)	Practical documents, less emphasis on formal standards	🥷 Tie

Conclusion

The **system under evaluation** produced a policy (Policy 2) that **outperforms the benchmark in most practical dimensions**:

- **More complete**, especially in areas of business continuity, risk analysis, and patch management.
- **Better adapted** to the real-world constraints of a small hospital.
- **More operationally useful** for implementation.

However, **ChatGPT's policy (Policy 1)** remains **stronger in terms of regulatory framing**, with clearer and more explicit alignment to GDPR, NIS2, and ISO/IEC standards. For formal documentation and audit-readiness, this remains an advantage.

Project Objective

This exercise supports a broader strategy to:

Benchmark different AI-generated policy outputs using ChatGPT as a reference, in order to evaluate the effectiveness of other systems (e.g., fine-tuned LLMs, RAG-based generators, rule-based augmentations) in producing compliance-grade, operationally sound cybersecurity documentation.